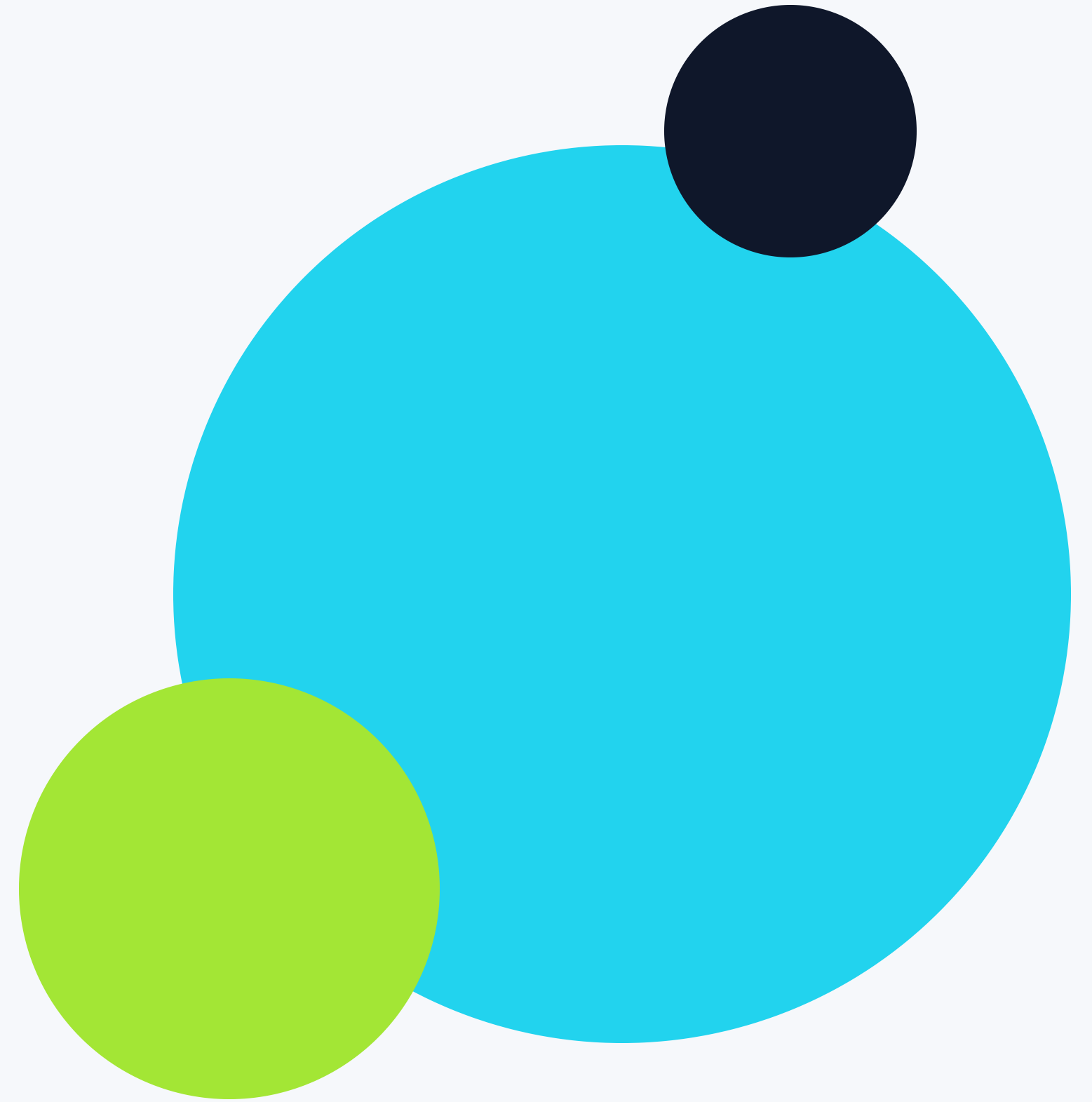


Authentication and access

El dominio que más pesa: 25 a 30% del examen.



HOY, EN 45 MINUTOS

Tú ya estudiaste. Aquí cazamos trampas

5'

Mapa

Cuatro subdominios y las cuatro preguntas que resuelven casi todo.

18'

Trampas

Doce trampas en once slides. Una frase para recordar cada una.

18'

Kahoot

Diez preguntas. Después de cada una, el porqué de cada distractor.

4'

Cierre

Qué estudiar esta semana y dónde están los links.

Cuatro subdominios, el que más pesa

**25 a
30%**

del examen. Ningún otro dominio pesa tanto.

1 · User authentication

TAP, passkeys, Authenticator, CBA, MFA tenant-wide, SSPR, WHfB, password protection, Entra Kerberos.

2 · Conditional Access

Plan, assignments, controls, troubleshooting, session, devices, CAE, authentication context, protected actions, templates.

3 · ID Protection

User risk, sign-in risk, registration campaigns, investigar y remediar usuarios y workload identities.

4 · Global Secure Access

Cliente, Private Access, Internet Access y el perfil de tráfico de Microsoft. Nuevo en el outline 2026.

LAS CUATRO PREGUNTAS QUE RESUELVEN CASI TODO M2

1 ¿Qué tan fuerte es el método?

MFA, passwordless o phishing-resistant. Y dónde se configura cada uno.

2 ¿Qué decide la política?

Si nadie dice que no, el token sale. El block, el break-glass y el context se diseñan a propósito.

3 ¿Qué riesgo es y cómo se cura?

User risk con password o risk remediation. Sign-in risk con MFA. Workload identities con otra licencia.

4 ¿Por dónde pasa el tráfico?

Microsoft, Private o Internet profile, y qué agrega cada uno.

TAP y passkeys: el pase y la llave

"La TAP es el pase de visitante, no tu llave. Y el passkey de Authenticator se configura en FIDO2, no en Authenticator."

Temporary Access Pass

- Vive de 10 minutos a 30 días, una por usuario. Con one-time, el registro passwordless se cierra a los 10 minutos.
- Authentication Admin la crea para usuarios sin rol; Privileged Authentication Admin también para admins. Nadie se la crea a sí mismo.

Passkeys (FIDO2)

- Passkey profiles por grupo: device-bound o synced, attestation y AAGUIDs. Synced passkeys no soportan attestation.
- Authenticator en modo Passwordless es phone sign-in, no passkey. El passkey de Authenticator se permite por AAGUID en Passkey (FIDO2).

Delata:

onboard passwordless

holds an administrator role

iCloud Keychain

verify the make and model

La escalera de métodos

"Phone sign-in es passwordless pero no phishing-resistant, y la TAP solo llega a MFA."

Phishing-resistant MFA	Passkeys FIDO2, Windows Hello for Business, platform credential, CBA multifactor.
Passwordless MFA	Todo lo anterior más Authenticator phone sign-in.
MFA	Todo lo anterior más Authenticator push, SMS, voz, OATH tokens y TAP.

CBA en tres líneas

- La CA va al trust store con CRL por HTTP. Sin CRL no hay revocación.
- Policy OID le gana al issuer.
Default: single-factor.
- No mezcles Require MFA con Require authentication strength en la misma política.

OAuth no es OATH

"OAuth es el token, OATH es el código de 6 dígitos. ¿Quieres forzar reauth? Sign-in frequency, no token lifetime."

2021

Desde el 30 de enero de 2021 el refresh token y el session token lifetime **ya no se configuran**. MaxAgeMultiFactor se ignora.

10 min a 24 h

AccessTokenLifetime solo mueve access, ID y SAML tokens. Al vencer, el refresh token renueva **en silencio**: el usuario no vuelve a escribir nada.

Sesión

Sign-in frequency fuerza reauth. Persistent browser session exige **All resources** y le gana al "Stay signed in?". Apaga Remember MFA antes.

Passwords que todavía importan

"Writeback se prende en dos lados, los admins viven en two-gate, y en Audit el password malo pasa."

SSPR

- Writeback pide P1 y se activa en el wizard de Connect y en On-premises integration. Con staged rollout no se garantiza.
- Los admins usan two-gate fijo: dos métodos y sin security questions. Prueba SSPR con un usuario sin rol.
- Desde el portal, Selected acepta un solo grupo.

Password protection

- Custom list: hasta 1000 términos de 4 a 16 caracteres.
- On-prem: proxy en un member server, DC agent en **todos** los DCs (con reboot). Los DCs no necesitan internet.
- Audit registra y acepta. Enforced rechaza.

Kerberos sin PKI

"Cloud Kerberos trust: cero PKI. Entra Kerberos en Azure Files: cero MFA para esa app."

WHfB híbrido con cloud Kerberos trust

1. Crear el objeto Microsoft Entra Kerberos con Set-AzureADKerberosServer.
2. Activar "Use cloud trust for on-premises authentication".
3. Enrolar con línea de vista al DC la primera vez. Si "Use certificate" está activo, gana certificate trust.

Azure Files con Entra Kerberos

1. Habilitar Entra Kerberos en el storage account y dar admin consent a su app.
2. Clientes con CloudKerberosTicketRetrievalEnabled.
3. Un solo identity source por storage account, y la app del storage **se excluye de las políticas de MFA.**

Construir CA sin logout

"Si nadie dice que no, Entra dice que sí. Para 'solo Finance' necesitas un block, y antes de todo, apaga security defaults."



Security defaults y CA no conviven. Apágalos primero (Conditional Access Administrator basta).



Una política de MFA para Finance no bloquea a nadie más. "Solo Finance" necesita una segunda política de block que excluya a Finance y a break-glass.



What If solo evalúa políticas On o report-only y no ve service dependencies. **Report-only** no sirve para User Actions.



Los templates nacen en report-only y solo excluyen a quien los crea. Agrega tus break-glass antes de encender.

Excluir el PAW, bloquear el resto

"Excluye el PAW y bloquea el resto: un device no registrado es null, y null no se excluye."

La receta del PAW

Assignment	Valor
Target resource	Windows Azure Service Management API
Filter for devices	Exclude filtered devices: extensionAttribute1 -eq "PAW"
Grant	Block access

Operadores positivos **no aplican** a devices no registrados; los negativos sí. Leer extensionAttributes pide Intune, compliant o hybrid.

Directory roles en CA: solo built-in. Guests: eliges tipo de usuario externo y tenant. **App enforced restrictions** da acceso limitado en SharePoint y Exchange sin productos extra.

Cortar el acceso ya

"CAE corta por eventos, no por cambios de grupo, y solo entiende IPs, no países."

CAE sí corta, en minutos

- Cuenta deshabilitada o borrada.
- Password cambiado o reseteado.
- MFA habilitado, refresh tokens revocados.
- User risk High. Cambio de IP contra named locations por IP.

CAE no corta

- Cambios de grupo o de política: hasta un día.
- Named locations por país.
- Guests. Y sin CAE, el access token vive hasta expirar.

Baja en híbrido, en orden

1. Deshabilitar en AD DS.
2. Reset de password, dos veces.
3. Revoke-MgUserSignInSession.
4. Deshabilitar sus devices.

Etiquetas y permisos

"El context es la etiqueta, la policy pone las reglas, y el que la pega es SharePoint, PIM o protected actions. La policy va en On, no en report-only."

1

Crea el context

c1 a c99, con Publish to apps activado.



2

CA policy que lo apunta

Grant: strength, compliant device.
Estado On. Sin mezclar el context con el directory role.



3

Alguien lo pega

SharePoint (sensitivity label o Set-SPOSite), PIM al activar, o protected actions sobre permisos de CA.

Riesgo: quién se cura con qué

USER RISK

La identidad probablemente está comprometida

Ejemplo: leaked credentials (siempre High, se ve con P1).

Se cura con password: secure password change, o
Require risk remediation (para passwordless revoca sesiones y pide sign-in).

SIGN-IN RISK

Este sign-in probablemente no es el dueño

Ejemplo: atypical travel, anonymous IP, unfamiliar properties.

Se cura con MFA: authentication strength y sign-in frequency Every time.



1 de octubre de 2026: se retiran las risk policies legacy de ID Protection. Todo va por CA. Nunca user risk y sign-in risk en la misma policy. Workload identities: licencia aparte y sin MFA.

GSA en un dibujo

"Microsoft primero, luego Private, luego Internet. Private Access mata la VPN, compliant network mata el token robado."

1 · MICROSOFT TRAFFIC

Con P1. Compliant network check, universal tenant restrictions (TRv2) y source IP restoration.

2 · PRIVATE ACCESS

Reemplaza la VPN. Connector, Quick Access, asignar sin nested groups. Per-app access cuando una app necesita otra CA.

3 · INTERNET ACCESS

Web filtering policy, security profile y CA con "All internet resources with Global Secure Access".

Cliente Windows: joined, hybrid o registered (registered solo Private Access). Sin AVD multi-session. Apagar QUIC y DNS over HTTPS.

BLOQUE 3 · 18 MINUTOS

Kahoot

Diez preguntas, 60 segundos cada una. Ganar no es el punto:
el porqué de cada distractor sí.

kahoot.it

PIN: en vivo

Dos grupos, dos reglas de passkeys

IT-Admins: only two approved key models, verify make and model.
HR: synced passkeys in iCloud Keychain. Least effort?

✓ **Passkey profiles: strict for IT-Admins, synced for HR**

B One FIDO2 policy with attestation and two AAGUIDs

C Authenticator Passwordless for HR, FIDO2 for IT-Admins

D Default FIDO2 plus a phishing-resistant CA policy

Por qué

Passkey profiles existen para reglas distintas por grupo: tipo, attestation y AAGUIDs. Hasta 3 perfiles incluido Default, y el opt-in no tiene regreso.

B. Synced passkeys no soportan attestation. HR no podría registrar iCloud Keychain.

C. Authenticator Passwordless es phone sign-in, no synced passkey.

D. Una strength controla el sign-in, no el registro, y no verifica marca y modelo.

Reautenticar cada 8 horas

Finance app: users must re-enter credentials at least every 8 hours.
What do you configure?

- A Token lifetime policy: MaxAgeMultiFactor 08:00:00
- B Token lifetime policy: AccessTokenLifetime 08:00:00
- ☒ C CA policy with Sign-in frequency 8 hours
- D Remember MFA on trusted devices

Por qué

Desde 2021 el refresh y session token lifetime **no se configuran**. Para forzar reauth, Learn dice **sign-in frequency**.

A. MaxAgeMultiFactor está retirado: se ignora.

B. Solo mueve el access token; el refresh token renueva en silencio.

D. Reduce prompts en vez de forzarlos, y hay que apagarlo antes de usar sign-in frequency.

Megan no puede usar SSPR

Megan (Helpdesk Admin) registered only security questions and can't use SSPR. Standard users can. Why?

- A SSPR is disabled for admins by default
- ☒ **Admins use a fixed two-gate policy, no security questions**
- C Nested groups aren't supported
- D Tenant must migrate to the Authentication methods policy

Por qué

Las cuentas con rol admin usan **two-gate**: dos métodos, sin security questions, y no se cambia. Por eso Learn dice: prueba SSPR con un usuario sin rol.

- A. Al revés: SSPR para admins viene habilitado.
- C. SSPR sí soporta nested groups, y Megan ya es miembro directo.
- D. Al revés: las security questions solo viven en la política legacy de SSPR.

Los perfiles dejaron de montar

AVD + FSLogix on Azure Files with Entra Kerberos. Profiles stopped mounting after an MFA policy for All resources. Fix?

✓ **Exclude the storage account app from the MFA policy**

B Add on-prem AD DS as a second identity source

C Add the kdc_enable_cloud_group_sids tag

D Configure a Kerberos realm mapping

Por qué

Learn lo marca como limitación: **Entra Kerberos para Azure Files no soporta MFA**. La app del storage account se excluye de las políticas de MFA.

B. Un storage account acepta un solo identity source.

C. Ese tag es para cloud-only y el límite de group SIDs.

D. El realm mapping es para convivir con AD DS, no arregla un bloqueo de CA.

Solo Finance entra a Payroll

CA01 requires MFA for Finance on Payroll. Others still open Payroll freely. Only Finance may access. What do you do?

- A Change CA01 to include All users
- ☒ **CA02: All users, exclude Finance and break-glass, Block**
- C CA01: Require one of the selected controls
- D CA02 in Report-only with Block

Por qué

Si ninguna política dispara un control, el token se emite. "Solo Finance" necesita una segunda política de block que excluya a Finance y a break-glass.

A. Todos entrarían con MFA. No es "solo Finance".

C. AND u OR entre controles no cambia a quién aplica.

D. Report-only no aplica controles, y sin excluir a Finance los bloquearías al encenderla.

Solo desde el PAW

Azure Service Management API only from PAWs (extensionAttribute1 = PAW). Unregistered devices must be blocked. Policy?

A Include filtered PAW devices, Block

☒ **Exclude filtered PAW devices, Block**

C Include filtered PAW devices, Require MFA

D Admin Portals, Windows, Require hybrid joined

Por qué

El patrón de Learn: **excluir los devices que cumplen el filtro y bloquear todo lo demás**. Un device no registrado es null, no lo excluye el operador positivo, y queda bloqueado.

A. Bloquearía justo a los PAW.

C. El filtro positivo no aplica a devices no registrados, y MFA no restringe a PAW.

D. Admin Portals no es Azure Resource Manager, y hybrid joined no significa PAW.

Phishing-resistant solo al activar

PIM-eligible Exchange Admins must use phishing-resistant MFA from a compliant device at activation only. What do you do?

- A PIM setting: require MFA on activation
- ☒ **Auth context + CA policy, then PIM requires that context**
- C CA policy on the Exchange Admin directory role
- D Protected action on the role assignment permission

Por qué

PIM puede pedir un **authentication context** al activar. La CA policy que apunta al context define strength y compliant device. Crea y enciende la policy antes.

A. Solo MFA, y puede no pedir nada si ya hubo MFA en la sesión.

C. Al activar, el usuario todavía no tiene el rol: la policy no aplica.

D. Protected actions protege permisos de CA, named locations y cross-tenant, no activaciones.

User risk para todos, con y sin password

P2 tenant, password and passwordless users. High user risk must self-remediate for both. Recommended before Oct 2026?

A Keep legacy user risk policy, add MFA

☒ CA: User risk High, grant Require risk remediation

C CA: User risk High, grant Require MFA

D CA: User + sign-in risk High, Require password change

Por qué

Require risk remediation se adapta: con password pide secure password change; en passwordless revoca sesiones y pide sign-in. Las legacy se retiran el 1 de octubre de 2026.

A. La legacy se retira y no ofrece este control.

C. MFA remedia sign-in risk, no user risk.

D. Nunca user risk y sign-in risk en la misma policy, y password change no sirve a passwordless.

Leaked credentials con P1

P1 tenant with PHS. Adele shows a Leaked credentials detection. Which action remediates the user risk?

- A Dismiss her user risk
- ☒ **Reset her password (temporary password)**
- C Require MFA at next sign-in
- D Revoke her sessions

Por qué

Leaked credentials es detección **nonpremium** (se ve con P1) y siempre High. **Un reset de password en la nube remedia** el riesgo, incluso para passwords on-prem, si hay PHS.

A. Dismiss cambia el estado, pero el password filtrado sigue siendo válido.

C. MFA remedia sign-in risk, no un password filtrado.

D. Corta tokens, no cambia el password.

Una app privada con otra política

ERP 10.20.5.20:443 must be Finance only with compliant device + MFA. The Quick Access policy must not change. What?

- A Add it to Quick Access, add compliant device to its CA
- ☒ **Per-app Global Secure Access app + its own CA policy**
- C Named location for 10.20.5.20 and block other locations
- D Nest Finance into the Quick Access group

Por qué

Una **Global Secure Access app (per-app access)** es para cuando un subconjunto de recursos o usuarios necesita otra política de CA. Quick Access es el bloque general.

A. Cambia la política de todo Quick Access y cualquier usuario asignado llegaría al ERP.

C. Named locations evalúan la IP de origen del usuario, no el destino.

D. Nested groups no se soportan, y no da otra política.

Antes de la sesión 3: Workload identities



Estudia M3

Guía del estudiante M3 y su banco de 40 preguntas: managed identities, enterprise apps, app registrations y Defender for Cloud Apps.



Repasa M2

Vuelve a lo que fallaste hoy. Las trampas 7, 11 y 12 son las que más se repiten en el examen.



Ojo con la fecha

Si presentas después del 1 de octubre de 2026, las risk policies legacy ya no existen: responde siempre con Conditional Access.

Si presentas el examen esta semana: llena el debrief el mismo día. Temas sí, preguntas no.

RECURSOS, TODOS CON LINK

Todo es público y de Microsoft Learn



Study guide y skills outline

Study guide for Exam SC-300



Practice assessment gratis

Practice Assessment SC-300



Learning path de M2

Implement an Authentication and Access Management solution



Global Secure Access

Deploy and configure Global Secure Access (módulo)



Migración de risk policies

Migrate risk policies to Conditional Access



Labs oficiales del curso

SC-300 Labs index en GitHub